
VU21995 – Manage the security infrastructure for the organisation

Risk Management - Controlling Risk

- *Weakness is a better teacher than strength. Weakness must learn to understand the obstacles that strength brushes aside*¹
- Involves implementing policies, procedures and automations to mitigate risks

¹Mason cooley, US Aphorist (1927 – 2002)

Objectives

- Identify risk strategies used to control risk
- Estimate risk controls and perform cost benefit analysis
- Maintain and prolong risk controls
- Explain industry approach to managing risk

Risk Control Strategies

An organization must choose one of five basic strategies to control risks:

- Defense – Apply safeguards that minimise or remove the uncontrolled risk.
- Transferral – passing on risks to other areas (outsource)
- Mitigation – minimise impact of an attack
- Acceptance – understanding the impact of leaving a risk uncontrolled
- Termination – eliminating or discontinuing the information asset from the organisation

Risk Control Strategy: Defense

Attempts to prevent the exploitation of the vulnerability

- Common methods of risk defense:
 - *Application of policy – ensure that policy is applied throughout the organisation e.g. IT policy*
 - *Training and education – risk awareness, education and training*
 - *Technology implementation – technical controls and safeguards*

Risk Control Strategy: Transferral

- Transfer risk to other assets or entities
 - Re-evaluate offered services
 - Re-evaluate deployment models
 - Outsource to other companies

Mitigation: Risk Control Strategy

- Minimise impact of risk associated with an incident
 - Planning and preparation is the key
- Mitigation plans
 - Incident response plan,
 - Disaster recovery plan
 - business continuity plan
- Key features
 - Detect and Respond quickly to incidents

Acceptance: Risk Control Strategy

- Do nothing - accept the consequence



- Decision can be deliberate or unconscious
- Understanding the consequences and accepting the risk without control or mitigation

■ NB Applies to an Organisation

- That has performed a risk assessment and analysis (cost benefit)

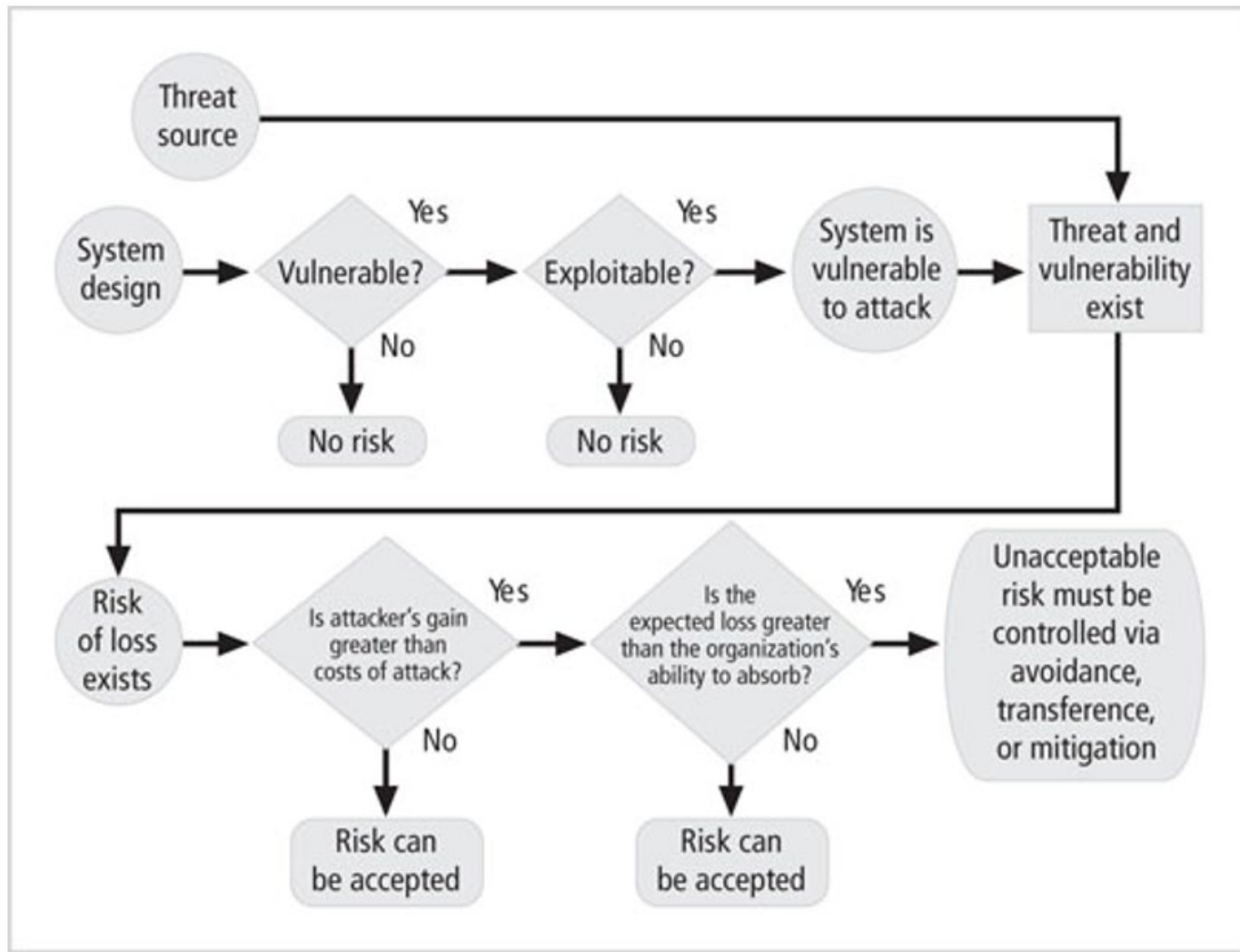
Termination: Risk Control Strategy

- Eliminate the risk
 - Based on the organisation decision
 - cheaper to get rid of the asset than protecting it

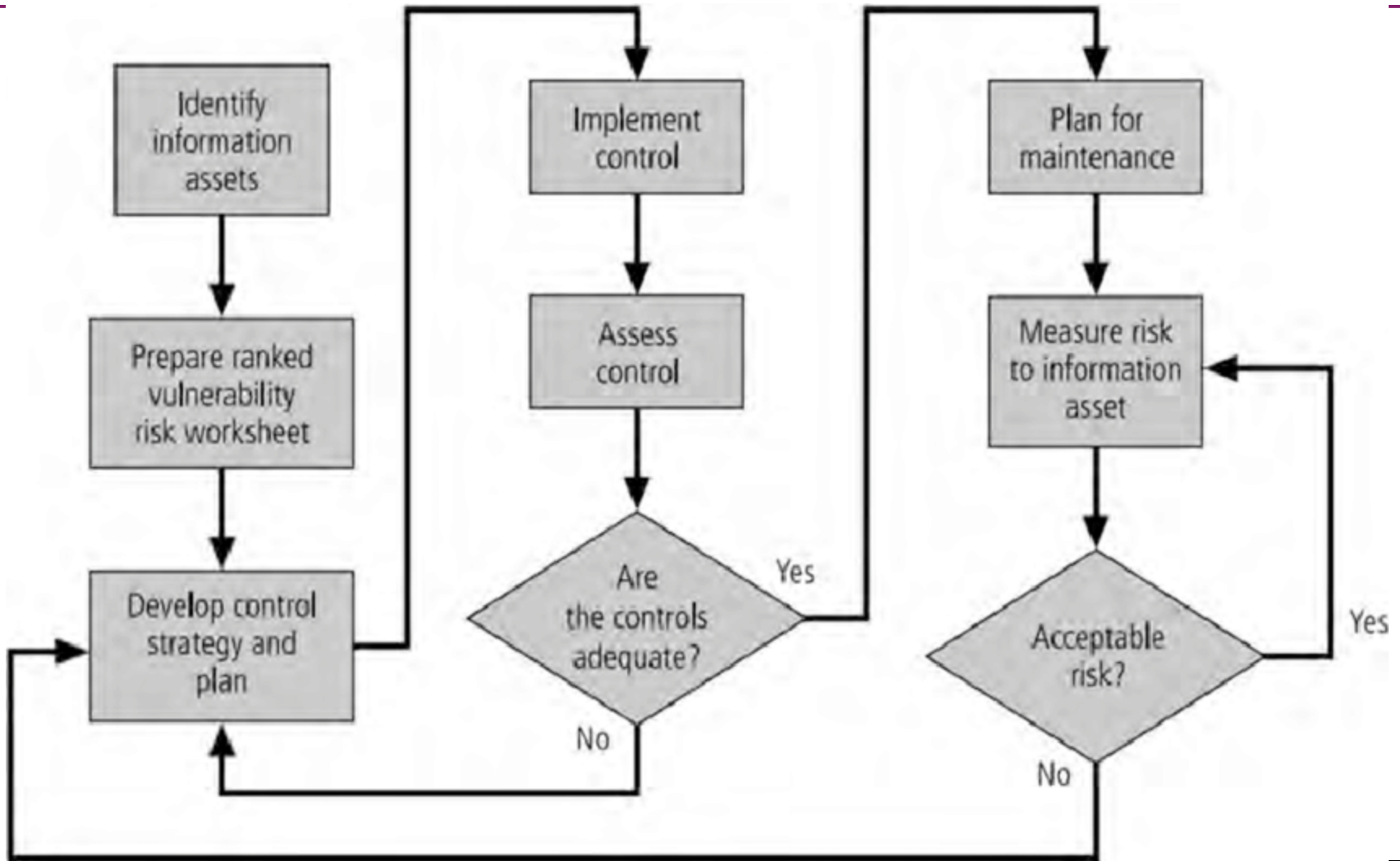
Managing Risk

- Risk appetite /Risk tolerance
 - Risk that an organisation is willing to take over unlimited access
 - Cost vs possible losses
- Residual risk
 - Risk leftover after implementing risk measures
- Rule of thumb
 - When a vulnerability exists in an important asset –implement security controls
 - When a vulnerability can be exploited
 - defense in depth
 - When the attacker's potential gain is greater than the costs of attack
 - Apply protection to increase the attacker's cost or reduce the attacker's gain by using technical or managerial controls
 - When the potential loss is substantial – apply design principles, a

Risk Handling Action Points



Risk Control Cycle



Feasibility and Cost-Benefit Analysis

- Before deciding on the strategy for a specific vulnerability
 - All readily accessible information about the consequences of the vulnerability must be explored
 - Ask “what are the advantages of implementing a control as opposed to the disadvantages of implementing the control?”
- There are a number of ways to determine the advantage or disadvantage of a specific control
- The primary means are based on the value of the information assets that it is designed to protect

Cost-Benefit Analysis

- Economic feasibility
 - The criterion most commonly used when evaluating a project that implements information security controls and safeguards
- Begin a cost-benefit analysis by:
 - Evaluating the worth of the information assets to be protected and the loss in value if those information assets are compromised
- This decision-making process is called
 - Cost-benefit analysis or economic feasibility study

Cost-Benefit Analysis (cont'd.)

- It is difficult to determine the value of information
 - It is also difficult to determine the cost of safeguarding it
- Factors that affect the cost of a safeguard
 - Cost of development or acquisition of hardware, software, and services
 - Training fees
 - Cost of implementation
 - Service and maintenance costs

Cost-Benefit Analysis (cont'd.)

- Benefit
 - The value to the organization of using controls to prevent losses associated with a specific vulnerability
 - Usually determined by valuing the information assets exposed by the vulnerability and then determining how much of that value is at risk and how much risk there is for the asset
 - This is expressed as the annualized loss expectancy (ALE)

Cost-Benefit Analysis (cont'd.)

- Asset valuation
 - The process of assigning financial value or worth to each information asset
 - The value of information differs within and between organizations
 - Based on the characteristics of information and the perceived value of that information
 - Involves estimation of real and perceived costs associated with the design, development, installation, maintenance, protection, recovery, and defense against loss and litigation

Cost-Benefit Analysis (cont'd.)

- Asset valuation components
 - Value retained from the cost of creating the information asset
 - Value retained from past maintenance of the information asset
 - Value implied by the cost of replacing the information
 - Value from providing the information
 - Value acquired from the cost of protecting the information

Cost-Benefit Analysis (cont'd.)

- Asset valuation components (cont'd.)
 - Value to owners
 - Value of intellectual property
 - Value to adversaries
 - Loss of productivity while the information assets are unavailable
 - Loss of revenue while information assets are unavailable

Cost-Benefit Analysis (cont'd.)

- An organization must be able to place a dollar value on each information asset it owns, based on:
 - How much did it cost to create or acquire?
 - How much would it cost to recreate or recover?
 - How much does it cost to maintain?
 - How much is it worth to the organization?
 - How much is it worth to the competition?

Cost-Benefit Analysis (cont'd.)

- Potential loss is that which could occur from the exploitation of vulnerability or a threat occurrence
- Ask these questions:
 - What loss could occur, and what financial impact would it have?
 - What would it cost to recover from the attack, in addition to the financial impact of damage?
 - What is the single loss expectancy for each risk?

Cost-Benefit Analysis (cont'd.)

- A single loss expectancy (SLE)
 - The calculation of the value associated with the most likely loss from an attack
 - SLE is based on the value of the asset and the expected percentage of loss that would occur from a particular attack
 - $SLE = \text{asset value (AV)} \times \text{exposure factor (EF)}$
 - Where EF is the percentage loss that would occur from a given vulnerability being exploited
 - This information is usually estimated

Cost-Benefit Analysis (cont'd.)

- In most cases, the probability of a threat occurring is the probability of loss from an attack within a given time frame
- This value is commonly referred to as the annualized rate of occurrence (ARO)
- $ALE = SLE * ARO$

Cost-Benefit Analysis (cont'd.)

- CBA determines whether or not a control alternative is worth its associated cost
- CBAs may be calculated before a control or safeguard is implemented
 - To determine if the control is worth implementing
- Or calculated after controls have been implemented and have been functioning for a time

Cost-Benefit Analysis (cont'd.)

- Cost-benefit analysis formula

$$\text{CBA} = \text{ALE}(\text{prior}) - \text{ALE}(\text{post}) - \text{ACS}$$

- ALE (prior to control) is the annualized loss expectancy of the risk before the implementation of the control
- ALE (post-control) is the ALE examined after the control has been in place for a period of time
- ACS is the annual cost of the safeguard

Other Methods of Establishing Feasibility

- Organizational feasibility analysis
 - Examines how well the proposed information security alternatives will contribute to the operation of an organization
- Operational feasibility
 - Addresses user and management acceptance and support
 - Addresses the overall requirements of the organization's stakeholders

Other Methods of Establishing Feasibility

- Technical feasibility
 - Examines whether or not the organization has or can acquire the technology to implement and support the alternatives
- Political feasibility
 - Defines what can and cannot occur based on the consensus and relationships between the communities of interest

Alternatives to Feasibility Analysis

- Benchmarking
- Due care and due diligence
- Best business practices
- Gold standard
- Government recommendations
- Baseline

Recommended Practices

- Organizations typically look for a more straightforward method of implementing controls
- This preference has prompted an ongoing search for ways to design security architectures that go beyond the direct application of specific controls for specific information asset vulnerability

Qualitative and Hybrid Measures

- Quantitative assessment
 - Performs asset valuation with actual values or estimates
 - May be difficult to assign specific values
- Qualitative assessment
 - Use scales instead of specific estimates
- Hybrid assessment
 - Tries to improve upon the ambiguity of qualitative measures without using an estimating process

Qualitative and Hybrid Measures

- The Operationally Critical Threat, Asset, and Vulnerability Evaluation (OCTAVE) Method
 - Defines the essential components of a comprehensive, systematic, context-driven, self-directed information security risk evaluation

A Single Source Approach to Risk Management

- The OCTAVE method (cont'd.)
 - Allows an organization to make information-protection decisions based on risks to the confidentiality, integrity, and availability of critical information technology assets
 - The operational or business units and the IT department work together to address the information security needs of the organization

The OCTAVE Methods

- Three variations of the OCTAVE method
 - The original OCTAVE method, (forms the basis for the OCTAVE body of knowledge)
 - Was designed for larger organizations with 300 or more users
 - OCTAVE-S
 - For smaller organizations of about 100 users
 - OCTAVE-Allegro
 - A streamlined approach for information security assessment and assurance
- For more information: www.cert.org/octave/

Microsoft Risk Management Approach

- Microsoft Corporation also promotes a risk management approach
- Four phases in the Microsoft InfoSec risk management process:
 - Assessing risk
 - Conducting decision support
 - Implementing controls
 - Measuring program effectiveness

Microsoft Risk Management Approach (cont'd.)

- Assessing Risk: Identification and prioritization of risks facing the organization
 - Plan data gathering – discuss keys to success and preparation guidance
 - Gather risk data – outline the data collection process and analysis
 - Prioritize risks – outline prescriptive steps to qualify and quantify risks

Microsoft Risk Management Approach (cont'd.)

- Conducting Decision Support: Identify and evaluate available controls
 - Define functional requirements – create the necessary requirements to mitigate risks
 - Select possible control solutions – outline approach to identify mitigation solutions
 - Review solution – evaluate proposed controls against functional requirements

Microsoft Risk Management Approach (cont'd.)

- Identify and evaluate available controls (cont'd.)
 - Estimate risk reduction – endeavor to understand reduced exposure or probability of risks
 - Estimate solution cost – evaluate direct and indirect costs associated with mitigation solutions
 - Select mitigation strategy – complete cost-benefit analysis to identify the most cost-effective mitigation solution

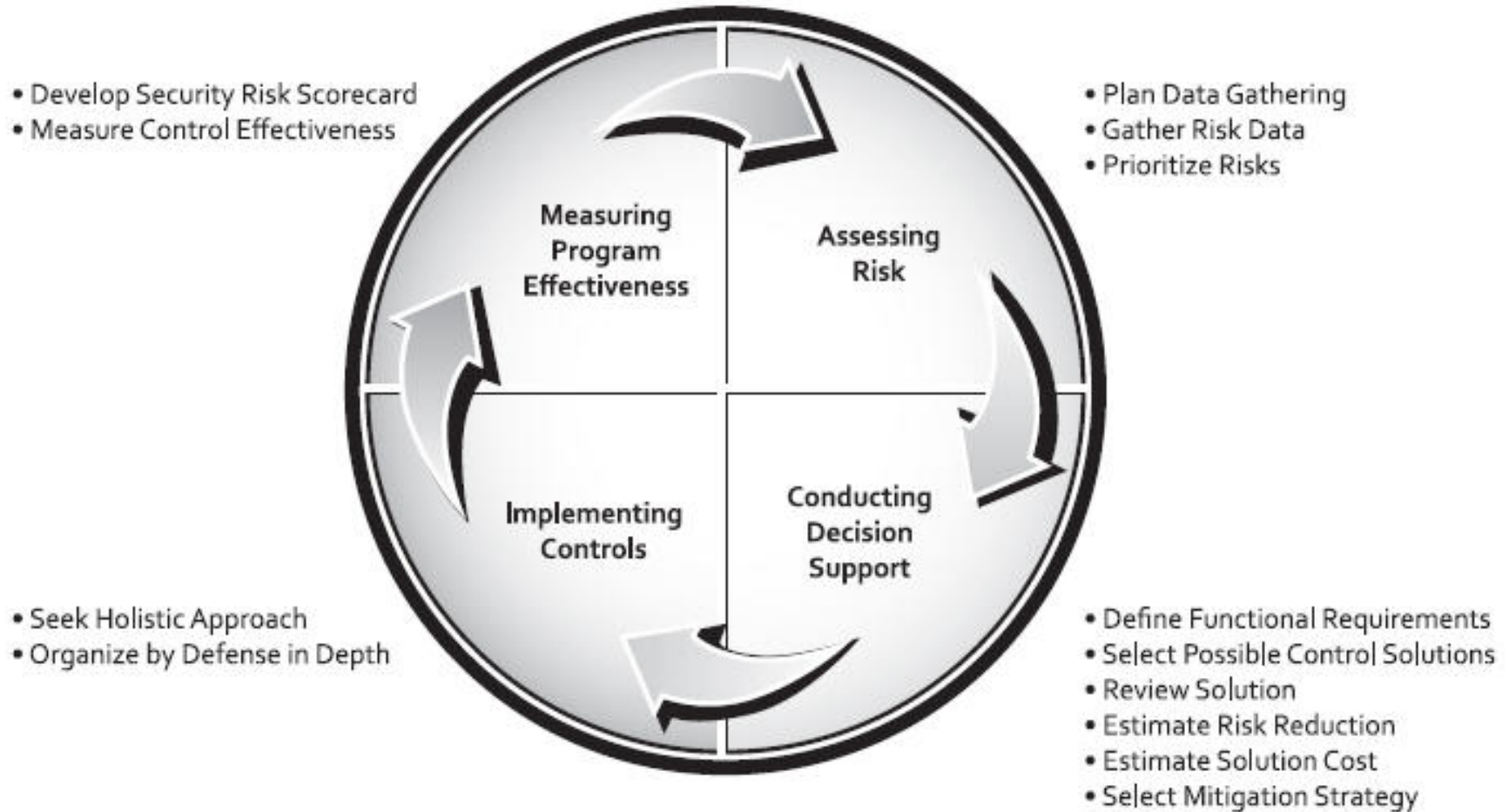
Microsoft Risk Management Approach (cont'd.)

- Implementing controls: deployment and operation of the controls selected from the cost-benefit analyses and other mitigating factors from the previous step
 - Seek holistic approach – incorporate people, process, and technology in mitigation solution
 - Organize by defense-in-depth – arrange mitigation solutions across the business

Microsoft Risk Management Approach (cont'd.)

- Measuring program effectiveness: ongoing assessment of the effectiveness of the risk management program
 - Develop risk scoreboard – understand risk posture and progress
 - Measure program effectiveness – evaluate the risk management program for opportunities to improve

Microsoft Risk Management Approach (cont'd.)



FAIR

- The Factor Analysis of Information Risk (FAIR) framework includes:
 - A taxonomy for information risk
 - Standard nomenclature for information risk terms
 - A framework for establishing data collection criteria
 - Measurement scales for risk factors
 - A computational engine for calculating risk

FAIR (cont'd.)

- The Factor Analysis of Information Risk (FAIR) framework includes: (cont'd.)
 - A modeling construct for analyzing complex risk scenarios
- See <http://fairwiki.riskmanagementinsight.com>

FAIR (cont'd.)

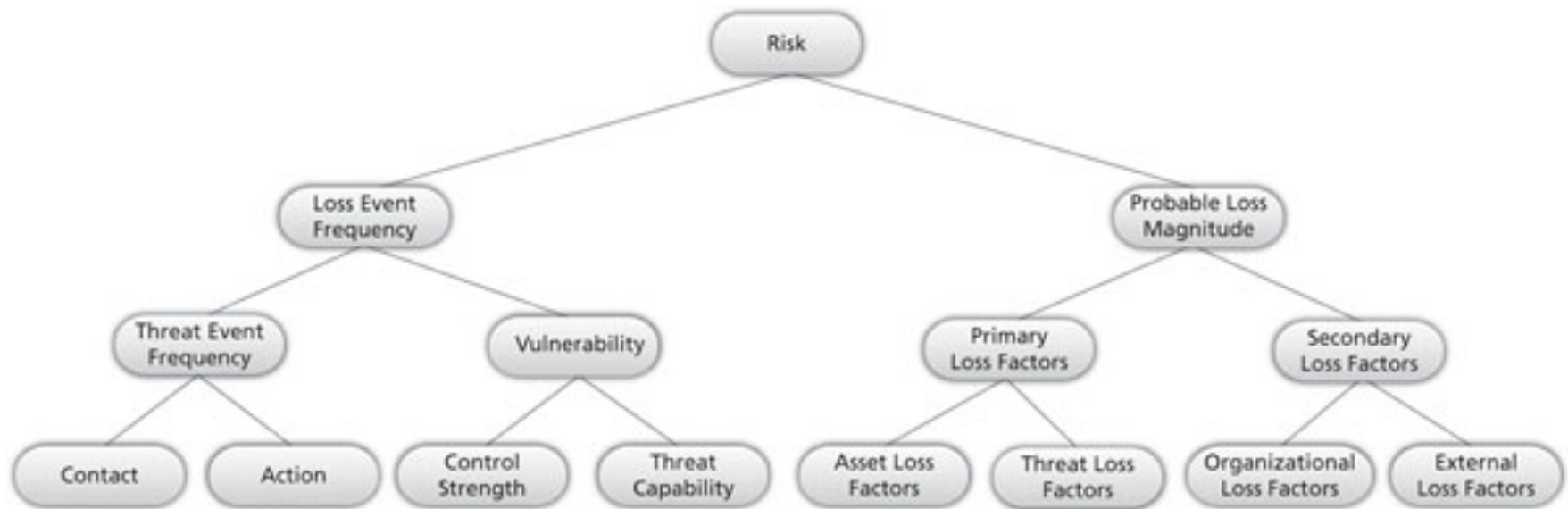
- Basic FAIR analysis is comprised of ten steps in four stages
- Stage 1 - Identify scenario components
 1. Identify the asset at risk
 2. Identify the threat community under consideration
- Stage 2 - Evaluate loss event frequency
 3. Estimate the probable threat event frequency
 4. Estimate the threat capability (TCap)
- Stage 2 - Evaluate loss event frequency (cont'd.)
 5. Estimate Control strength (CS)
 6. Derive Vulnerability (Vuln)
 7. Derive Loss Event Frequency (LEF)

FAIR (cont'd.)

- Stage 3 - Evaluate probable loss magnitude (PLM)
 - 8. Estimate worst-case loss
 - 9. Estimate probable loss
- Stage 4 - Derive and articulate Risk
 - 10. Derive and articulate Risk
- Unlike other risk management frameworks, FAIR relies on the qualitative assessment of many risk components using scales with value ranges, for example very high to very low

FAIR (cont'd.)

Factor analysis of information risk (FAIR)



ISO 27005 *Standard for Information Security Risk Management*

- The ISO 27000 series includes a standard for the performance of Risk Management
 - ISO 27005
 - See <http://www.27000.org/iso-27005.htm>

ISO 27005 *Standard for Information Security Risk Management*

- The 27005 document includes a five-stage risk management methodology
 - Information security risk assessment (ISRA)
 - Information security risk treatment
 - Information security risk acceptance
 - Information security risk communication
 - Information security risk monitoring and review

Other Methods

- European Network and Information Security Agency (ENISA)
 - https://www.enisa.europa.eu/topics/threat-risk-management/risk-management/current-risk/business-process-integration/files/enisa_rm_op_process_flyer.pdf
- New Zealand's IsecT Ltd
- Maintains IsecT 27001 Security website <http://iso27001security.com>

SUMMARY

- Introduction
- Risk control strategies
- Risk control strategy selection
- Categories of controls
- Feasibility studies and cost-benefit analysis
- Risk management discussion points
- Recommended risk control practices
- The OCTAVE method
- The Microsoft risk management approach
- FAIR
- ISO 27005 *Standard for Information Risk Management*

Management of Information Security, 4th ed.

www.microsoft.com/technet/security/topics/complianceandpolicies/secrisk/default.msp

<http://fairwiki.riskmanagementinsight.com>